CONFIDENTIAL — CONTAINS DETAILS OF SECURITY SAFEGUARDS

HIPAA SECURITY RULE · SECURITY RISK ANALYSIS

# Riverside Family Medicine (sample)

ASSESSMENT DATE
**November 10, 2026**

NEXT REVIEW DUE
**November 10, 2027**

COMPLETED BY
**Jordan Lee, Practice Manager**
Practice staff

SECURITY OFFICER
**Dr. Sam Patel, Owner**

OVERALL RISK
High risk
39% of measured risk remains
(75.5 of 192 points)

FINDINGS
**18 total**
1 critical · 4 high · 9 medium · 4 low

Practice address

NPI (optional)

## 1. Scope and method

This analysis covers the practice's administrative, physical, and technical safeguards for electronic protected health information (ePHI), including AI tools that access ePHI, as required by 45 CFR 164.308(a)(1)(ii)(A). 38 safeguards were assessed.

- **Sources:** HIPAA Security Rule (45 CFR Part 164, Subpart C) as currently in force; Breach Notification Rule (45 CFR 164.404); NIST SP 800-30 Rev. 1 (risk assessment method); NIST SP 800-66 Rev. 2 (Security Rule implementation guidance).
- **Risk per safeguard:** likelihood (1–3) × impact (1–3), from 1 to 9 points. Yes leaves 0% of that risk, Partially 50%, No 100%. N/A answers are excluded.
- **Overall rating:** remaining risk as a share of the maximum. Below 15% Low, 15–39% Medium, 40% or more High. Any critical safeguard answered No raises the rating to at least High; Partially, to at least Medium.
- **Critical safeguards:** risk analysis, tested backups, device encryption, multi-factor authentication, Business Associate Agreements, and an incident response plan.
- **Proposed rule:** notes on the January 2025 proposed Security Rule are informational only; that rule is not final and is not scored.

## 2. Results by area

| Area | Questions | N/A | Risk remaining | Rating |
|---|---|---|---|---|
| **Administrative Safeguards** | 11 | 0 | 24% | Medium risk |
| **Physical Safeguards** | 5 | 0 | 39% | Medium risk |
| **Technical Safeguards** | 9 | 0 | 36% | Medium risk |
| **Vendors and Business Associates** | 2 | 0 | 63% | High risk |
| **Policies and Incident Response** | 3 | 0 | 21% | Medium risk |
| **Documentation** | 2 | 0 | 0% | Low risk |
| **AI Tools** | 6 | 0 | 77% | High risk |

## 3. Risk management plan

Findings in priority order. Assign an owner and target date to each, and record completion.

| # | Severity | Finding and remediation | Due in | Owner | Done (date) |
|---|---|---|---|---|---|
| 1 | Critical | **Are all laptops, phones, tablets, and USB drives that store or access patient data encrypted?**<br>TEC-003 · 45 CFR 164.312(a)(2)(iv) · Answer: No<br>Turn on BitLocker or FileVault on every computer, require passcodes on phones, and stop using unencrypted USB drives. | 7 days | | |
| 2 | High | **Do you have a written rule that staff may not enter patient information into public AI chatbots or other AI tools the practice has not approved?**<br>AI-005 · 45 CFR 164.308(a)(1)(ii)(B) · Answer: No<br>Add a short AI use policy listing approved tools, ban unapproved tools for patient information, and cover it in annual training. | 30 days | | |

| # | Severity | Finding and remediation | Due in | Owner | Done (date) |
|---|---|---|---|---|---|
| 3 | High | **Do you keep a list of every AI tool your practice uses that can see patient information?**<br>AI-001 · 45 CFR 164.308(a)(1)(ii)(A) · Answer: No<br>List each AI tool, the vendor, what patient information it sees, and who uses it. Add it to your device and vendor lists and review it at each risk analysis. | 30 days | | |
| 4 | High | **Does your incident response plan cover problems with AI tools, such as an AI vendor breach or an AI tool exposing patient information?**<br>AI-006 · 45 CFR 164.308(a)(6)(ii) · Answer: No<br>Add an AI section to your incident response plan, covering how to disable each AI tool, the vendor's security contact, how to preserve logs, and notifying the Security Officer right away. Review it with your annual plan test. | 30 days | | |
| 5 | High | **Do you have a written plan for keeping the practice running if your systems are unavailable (e.g., outage, ransomware, fire)?**<br>ADM-011 · 45 CFR 164.308(a)(7)(ii)(B) · Answer: No<br>Write a one- to two-page plan covering emergency contacts, how to access backups, paper workflows, and how to restore systems. | 60 days | | |
| 6 | Medium | **Is multi-factor authentication (MFA) required for email and for any access to the EHR from outside the office?**<br>TEC-004 · 45 CFR 164.312(d) · Answer: Partially<br>Turn on MFA for email, the EHR, remote access, and any admin accounts. Start with email — it is usually the fastest win. | 7 days | | |
| 7 | Medium | **Is one specific person officially named as your Security Officer?**<br>ADM-003 · 45 CFR 164.308(a)(2) · Answer: No<br>Designate a Security Officer in a signed memo, and list their responsibilities. | 7 days | | |

| # | Severity | Finding and remediation | Due in | Owner | Done (date) |
|---|---|---|---|---|---|
| 8 | Medium | **Do you know whether each AI vendor can use your patients' information to train its models, and how long it keeps the data?**<br>AI-003 · 45 CFR 164.504(e)(2) · Answer: No<br>Get written answers from each AI vendor on model training, data retention, and deletion, and make sure the BAA reflects them. | 30 days | | |
| 9 | Medium | **Do you keep a list of every computer, laptop, phone, tablet, and storage device that can access patient data?**<br>PHY-005 · 45 CFR 164.310(d)(1) · Answer: No<br>Create a simple spreadsheet listing each device, its user, location, and whether it is encrypted. Update it whenever devices change. | 30 days | | |
| 10 | Medium | **Do you have a signed Business Associate Agreement (BAA) with every outside company that handles patient information for you?**<br>ORG-001 · 45 CFR 164.308(b)(1) · Answer: Partially<br>List every vendor that touches patient data, request a BAA from each one, and store signed copies together. | 14 days | | |
| 11 | Medium | **Do all workforce members complete HIPAA security training when hired and at least once a year?**<br>ADM-008 · 45 CFR 164.308(a)(5)(i) · Answer: Partially<br>Choose a training course (HHS provides free materials), train everyone, and keep dated records of completion. | 30 days | | |
| 12 | Medium | **Before disposing of computers, drives, phones, or copiers, do you securely wipe or destroy the storage?**<br>PHY-004 · 45 CFR 164.310(d)(2)(i) · Answer: Partially<br>Use a certified data destruction vendor (and sign a BAA with them), and keep certificates of destruction. | 30 days | | |

| # | Severity | Finding and remediation | Due in | Owner | Done (date) |
|---|---|---|---|---|---|
| 13 | Medium | **Do you have a written plan for responding to a security incident, such as a hacked account, ransomware, or a lost laptop?**<br>POL-001 · 45 CFR 164.308(a)(6)(ii) · Answer: Partially<br>Write a one-page incident response plan with emergency contacts (IT provider, EHR vendor, cyber insurer, attorney) and the first steps to take. | 30 days | | |
| 14 | Medium | **Is patient information encrypted when sent by email or transferred over the internet?**<br>TEC-005 · 45 CFR 164.312(e)(2)(ii) · Answer: Partially<br>Enable your email provider's encryption option (or a secure messaging tool) and train staff on when to use it. | 30 days | | |
| 15 | Low | **Do computers lock or log out automatically after a period of inactivity?**<br>TEC-002 · 45 CFR 164.312(a)(2)(iii) · Answer: Partially<br>Set an automatic screen lock on every workstation and enable the EHR's session timeout. | 7 days | | |
| 16 | Low | **Does someone regularly review EHR access logs or reports for unusual activity?**<br>ADM-005 · 45 CFR 164.308(a)(1)(ii)(D) · Answer: Partially<br>Ask your EHR vendor how to run an access report. Have the Security Officer review it monthly and keep a dated note of each review. | 30 days | | |
| 17 | Low | **Does a clinician review AI-generated notes, summaries, or codes before they are saved to the record or billed?**<br>AI-004 · 45 CFR 164.312(c)(1) · Answer: Partially<br>Require the treating clinician to review and sign AI-generated documentation before it is final, and include this in your AI policy and training. | 30 days | | |

| # | Severity | Finding and remediation | Due in | Owner | Done (date) |
|---|---|---|---|---|---|
| 18 | Low | **Do you keep a current list of all vendors with BAAs, including when each agreement was signed?**<br>ORG-002 · 45 CFR 164.314(a) · Answer: No<br>Create a vendor list with contact, service, BAA date, and renewal date, and review it every 12 months. | 30 days | | |

## 4. Review and approval

I attest that the information in this assessment is true and complete to the best of my knowledge, that I have reviewed the risk management plan above, and that this assessment will be retained for at least six years as required by 45 CFR 164.316(b)(2)(i).

| Security Officer — printed name | Signature | Date |
|---|---|---|
| Practice owner / administrator — printed name | Signature | Date |

Next review due: within 12 months of the date above, or sooner after a major change or security incident.

Prepared with Open Clinic SRA, a free open-source tool. This report is a structured self-assessment to support the practice's HIPAA risk analysis. It is not legal advice and does not certify HIPAA compliance. Keep this report for at least 6 years (45 CFR 164.316(b)(2)).